

Security Review

Scope	The LearnHub application (<code>src/LearnHub</code>), its configuration, the container (<code>Dockerfile</code> , <code>railway.json</code>), the CI workflows in <code>.github/workflows</code> and the repository contents
Method	Manual code review against the OWASP Top 10:2025 and the assignment's security requirements (SEC-01 to SEC-11), backed by automated tests that attack the running application
Date	14 September 2026
Result	No open high or medium findings. Residual risks and hardening ideas are listed in section 4.

1. Summary of controls

Area	Control	Where
Authentication	ASP.NET Core Identity with PBKDF2 password hashing; 8–100 characters with upper-case, lower-case and digit; unique email; logout after 5 failures for 15 minutes; generic error for wrong passwords; one message for logout and deactivation	<code>Infrastructure/ServiceCollectionExtensions.cs</code> , <code>Controllers/AccountController.cs</code> , <code>ViewModels/Account/AccountViewModels.cs</code>
Sessions	Cookies <code>HttpOnly</code> , <code>SameSite=Lax</code> , <code>Secure</code> outside Development; 8-hour sliding expiry; security stamp re-checked every 5 minutes so role changes and deactivation apply quickly	<code>Infrastructure/ServiceCollectionExtensions.cs</code>
Authorisation	<code>[Authorize(Roles = "Student")]</code> on student controllers; every admin controller inherits <code>AdminControllerBase</code> (<code>[Area("Admin")]</code>) , <code>[Authorize(Roles = "Admin")]</code> , so a new admin page cannot be added unprotected	<code>Controllers/</code> , <code>Areas/Admin/Controllers/AdminControllerBase.cs</code>
Access to data	Services check enrolment or ownership before returning lessons, files, quizzes and results (IDOR)	<code>Services/LearningResourceService.cs</code> , <code>Services/QuizService.cs</code> , <code>Controllers/ResourcesController.cs</code>
CSRF	Global <code>AutoValidateAntiforgeryTokenAttribute</code> ; every state change is a POST form with a token	<code>Infrastructure/ServiceCollectionExtensions.cs</code>
Injection	Only EF Core LINQ (parameterised SQL); search terms go through <code>EF.Functions.Like</code> with <code>%</code> , <code>_</code> and <code>[</code> escaped	<code>Services/SearchPattern.cs</code> , <code>Services/CourseCatalogService.cs</code>
XSS	Razor encodes all output; lesson text is encoded first, then a fixed allow-list of formatting is applied; strict Content Security Policy without inline scripts or styles	<code>Services/Content/LessonContentRenderer.cs</code> , <code>Infrastructure/SecurityHeadersMiddleware.cs</code>
Embedded video	URLs parsed with strict host and id rules and rebuilt as <code>youtube-nocookie.com</code> or <code>player.vimeo.com</code> embed URLs; CSP <code>frame-src</code> allows only those players	<code>Services/Content/VideoEmbedParser.cs</code>
Overposting	Forms bind to view models; services copy allowed fields onto entities	<code>ViewModels/</code> , <code>Services/*ManagementService.cs</code>
File uploads	Extension allow-list (JPG, PNG, WebP up to 2 MB; PDF up to 10 MB), magic-byte signature check, size checked on the stream, random file names, storage outside <code>wwwroot</code> , files streamed only after an access check, SVG and HTML never accepted	<code>Services/Storage/UploadRules.cs</code> , <code>Services/Storage/FileStorageService.cs</code> , <code>Infrastructure/FileValidationAttributes.cs</code>
Abuse	Fixed-window rate limit (10 requests per 60 seconds per IP) on login, registration, password change and contact; honeypot field on the contact form	<code>Infrastructure/ServiceCollectionExtensions.cs</code> , <code>Services/ContactService.cs</code>
Transport and headers	HTTPS redirection and HSTS in production; <code>Content-Security-Policy</code> , <code>X-Content-Type-Options: nosniff</code> , <code>X-Frame-Options: SAMEORIGIN</code> , <code>Referrer-Policy</code> , <code>Permissions-Policy</code> , <code>Cross-Origin-Opener-Policy</code> ; compression only for static assets (BREACH)	<code>Program.cs</code> , <code>Infrastructure/SecurityHeadersMiddleware.cs</code>
Trusted proxy	<code>UsePlatformProxyHeaders()</code> honours the platform proxy's <code>X-Forwarded-Proto</code> and <code>X-Forwarded-For</code> , so <code>Request.IsHttps</code> and the client address are correct behind the TLS-terminating edge. The container must only be reachable through that proxy (the trade-off is stated below and in section 4)	<code>Infrastructure/ApplicationBuilderExtensions.cs</code> , <code>Program.cs</code>
Errors	Developer exception page only in Development; friendly 404 and 500 pages; no stack traces; structured logging	<code>Program.cs</code> , <code>Controllers/ErrorController.cs</code>
Secrets	No passwords or keys in Git; demo passwords generated into a git-ignored file in Development; <code>Seed__AdminPassword</code> and <code>Seed__DemoStudentPassword</code> from environment variables in production; <code>.env</code> git-ignored while <code>.env.example</code> holds placeholders only	<code>appsettings.json</code> (empty seed passwords), <code>Data/Seed/DevelopmentSeedPasswords.cs</code> , <code>.env.example</code> , <code>.gitignore</code>

Content Security Policy sent with every HTML response:

```
default-src 'self'; script-src 'self'; style-src 'self'; img-src 'self' data:; font-src 'self'; connect-src 'self';
media-src 'self'; frame-src 'self' https://www.youtube-nocookie.com https://player.vimeo.com; object-src 'none';
base-uri 'self'; form-action 'self'; frame-ancestors 'self'
```

Trusting the platform proxy's forwarded headers

Railway terminates TLS at its edge proxy and forwards plain HTTP, describing the original request in `X-Forwarded-Proto` and `X-Forwarded-For`. ASP.NET Core does not read those headers on its own, and its default allow-list trusts them only from loopback, which is not where the platform proxy lives.

`UsePlatformProxyHeaders()` therefore clears `KnownIPNetworks` and `KnownProxies`, so both headers are honoured **from any source**.

That is a deliberate trade-off, and the condition it depends on is: the application must only be reachable through that proxy. On Railway it is — the container publishes one HTTP port to the platform edge and nothing else routes to it, and the image is never given a directly reachable public address. The residual risk is that anything able to reach the container directly could forge the headers. Two consequences matter:

- `X-Forwarded-Proto` decides `Request.IsHttps`, so a forged value influences HSTS, the HTTPS redirection decision and the `Secure`-only cookie policy.
- The forms rate limiter partitions on `context.Connection.RemoteIpAddress`, so a forged `X-Forwarded-For` would let a caller present itself as a new address, start a fresh 10-requests-per-minute bucket and weaken the limit on login, registration, password change and contact.

The risk is accepted for this single-service deployment because the proxy is the only ingress. Exposing the container on a public address, or adding a second ingress, would require restoring a known-proxy allow-list (the platform's egress range) instead of clearing it.

2. OWASP Top 10:2025

Risk	How LearnHub addresses it	Evidence (automated tests)	Status
A01 Broken Access Control	Role attributes, admin base class, ownership and enrolment checks in services, files streamed through a controller, local-only return URLs	<code>AuthorizationTests</code> (access matrix, <code>Students_cannot_post_to_admin_actions_even_with_a_valid_token</code> , <code>Access_denied_page_returns_403</code>); <code>QuizAndCourseManagementTests.Students_cannot_open_other_students_results_but_admins_can</code> ; <code>Students_who_are_not_enrolled_cannot_take_or_submit_the_quiz</code> ; <code>StudentJourneyTests.Leaving_a_course_removes_access_to_its_lessons</code> ; <code>PublicSiteTests.Private_files_cannot_be_downloaded_by_guests</code> ; <code>AuthenticationTests.Login_redirects_back_to_a_local_return_url_but_never_to_another_site</code>	Address
A02 Security Misconfiguration	Production defaults: HTTPS, HSTS, secure cookies, CSP and headers, no developer pages; the image runs as Production and binds one HTTP port behind the platform's TLS-terminating proxy	<code>PublicSiteTests.Html_responses_carry_security_headers</code> ; smoke test header checks in the container job	Address
A03 Software Supply Chain Failures	Central package versions (<code>Directory.Packages.props</code>), pinned GitHub Actions major versions, vendored front-end libraries with recorded versions, lock file for browser tests	Build in CI from a clean runner on every push	Partly address: (see 4)
A04 Cryptographic Failures	Identity password hashing; TLS enforced; ASP.NET Core Data Protection for cookies and tokens; no custom cryptography	<code>AuthenticationTests.Registration_creates_a_student_signs_them_in_and_hashes_the_password</code>	Address
A05 Injection	EF Core parameterised queries, escaped LIKE patterns, encoded output, CSP	<code>ContentSafetyTests</code> (<code>Html_in_lesson_text_is_encoded_and_never_executed</code> , <code>Attack_attempts_through_formatting_markers_stay_as_text</code>); search tests	Address
A06 Insecure Design	Server-side grading from stored answers, correct answers never sent to the browser, score snapshots, unique indexes against double submissions, last-administrator protection	<code>StudentJourneyTests.Tampered_quiz_answers_are_graded_on_the_server</code> ; <code>QuizAndCourseManagementTests.The_quiz_page_never_contains_the_correct_answers</code> ; <code>Option_ids_that_belong_to_another_question_are_not_modified</code> ; <code>AdminManagementTests.User_roles_deactivation_and_self_protection</code>	Address
A07 Authentication Failures	Password policy on client and server, logout, generic messages, rate limiting, security stamp validation, deactivation through logout	<code>AuthenticationTests.Account_is_locked_after_five_failed_attempts</code> ; <code>Wrong_password_shows_a_generic_error</code> ; <code>LogicTests.Register_requires_matching_strong_passwords_and_accepted_terms</code>	Address
A08 Software or Data Integrity Failures	Antiforgery tokens on every POST; uploads verified by content signature; the image is built from this repository by Railway and the presentation site is deployed from the same repository, so no artefact is copied by hand	<code>AuthenticationTests.Posts_without_an_anti_forgery_token_are_rejected</code> ; <code>FileStorageServiceTests.Rejects_a_file_whose_content_does_not_match_its_extension</code> ; <code>Rejects_files_over_the_size_limit_even_if_the_declared_length_is_small</code>	Address

Risk	How LearnHub addresses it	Evidence (automated tests)	Status
A09 Security Logging and Alerting Failures	Structured logs for sign-in failures, lockouts, seeding, administrator creation, enrolments, deletions and discarded spam; the container log, which the <code>container</code> job keeps as an artifact	Both the <code>container</code> and <code>e2e</code> jobs fail if the application logs a <code>fail:</code> or <code>crit:</code> line	Partly address: (see 4)
A10 Mishandling of Exceptional Conditions	Global exception handler with friendly pages; <code>DbUpdateException</code> from unique indexes turned into clear messages; transactions with the execution strategy; database health check	<code>NavigationCrawlTests</code> (no 500 responses for guest, student or admin); <code>PublicSiteTests.Unknown_pages_and_invalid_ids_return_a_friendly_404</code> ; <code>Health_endpoint_reports_the_database_as_healthy</code>	Address

3. Assignment security requirements

SEC-04 IDOR (insecure direct object references)

Every identifier in a URL is treated as untrusted:

- `/Quizzes/Result/{id}` returns the attempt only when it belongs to the signed-in student. Another student's id gives 404 rather than 403, so attempt ids cannot be probed. Administrators review attempts in **Admin → Quiz results**.
- `/Resources/Details/{id}` and `/Resources/Open/{id}` allow preview lessons for everyone; other lessons require enrolment in that course (or the Admin role). Files are never served from `wwwroot`.
- `/Quizzes/Take/{id}` requires enrolment and a published quiz, and a submitted option is accepted only if it belongs to that question.
- Admin actions are available only to administrators, even with a valid antiforgery token.

SEC-02 XSS

- Razor encodes every value by default; the code base does not render user input with `Html.Raw`. Lesson bodies go through `LessonContentRenderer`, which encodes the whole text before applying paragraph, list, heading, code and emphasis formatting from a fixed allow-list.
- The CSP blocks inline scripts, event-handler attributes and scripts from other origins, so even an unexpected injection could not run code.
- Category icons come from a fixed allow-list, and video URLs are rebuilt rather than echoed.

SEC-03 CSRF

- `AutoValidateAntiforgeryTokenAttribute` is registered globally, so every POST, PUT and DELETE needs a valid token. The form tag helper adds the token automatically.
- State changes are never done with GET: enrol, leave, complete, submit, publish, delete and log out are all POST forms.
- `SameSite=Lax` cookies add a second layer.

SEC-06 Uploads

The upload pipeline in `FileStorageService` rejects a file unless every check passes:

- A file was chosen and its extension is on the allow-list for that use (course cover: image; resource: image or PDF).
- The size is within the limit, measured while copying rather than trusting the declared length.
- The first bytes match a JPEG, PNG, WebP or PDF signature, and the detected type fits the extension.
- The file is saved under a new random name with the detected extension, in `Storage:RootPath` outside `wwwroot`.

Uploaded files are served by `ResourcesController.Open` after the access check, with the stored content type and `X-Content-Type-Options: nosniff`. Course covers are the only uploads shown as public images.

SEC-08 Secrets

- `appsettings.json` contains no passwords (`Seed:AdminPassword` and `Seed:DemoStudentPassword` are empty) and no connection string with credentials: SQLite is a file, so `ConnectionStrings:DefaultConnection` is just a path.
- Development.** `DevelopmentSeedPasswords` generates strong random passwords for the demo accounts and writes them to `App_Data/demo-credentials.json`, which is git-ignored (`App_Data/` is excluded wholesale). They are generated once and reused on later starts, so signing in as a demo account keeps working without a committed password.
- Production.** The administrator and demo-student passwords must come from the environment variables `Seed__AdminPassword` and `Seed__DemoStudentPassword` (Railway service variables, or `.env` locally). With no password set the account is still created but cannot sign in, and the application logs a warning rather than inventing one. A password can also be set with `dotnet user-secrets` for local use.
- `.env` is git-ignored; `.env.example` documents every variable with placeholders only, so the repository can be cloned and configured without ever holding a real credential.
- CI generates throw-away passwords for the container and browser-test accounts at run time and masks them in the logs. The only fixed passwords in the repository are synthetic ones in `tests/LearnHub.Tests/Infrastructure/LearnHubWebApplicationFactory.cs` for temporary in-memory test databases.
- A repository scan for assignments of password, secret, key, token or connection string values found nothing except those synthetic test values.

SEC-05 Overposting

Controllers accept view models that contain only the fields a form may change. For example, a student profile update cannot set roles, and a course form cannot set `CreatedAt`. Services load the entity and copy the allowed values.

4. Residual risks and recommendations

Risk	Current state	Recommendation
Forwarded headers are trusted from any source	<code>KnownIPNetworks</code> and <code>KnownProxies</code> are cleared so the platform proxy's headers are honoured (see section 1). Safe only while the proxy is the sole ingress	If the container ever becomes directly reachable or gains a second ingress, restore a known-proxy allow-list; otherwise a forged <code>X-Forwarded-For</code> can influence the per-IP rate limiter and a forged <code>X-Forwarded-Proto</code> the secure-cookie and HSTS decisions
No email verification or password reset by email	Registration signs in immediately; forgotten passwords need an administrator	Add an email provider, <code>RequireConfirmedAccount</code> and the Identity password-reset flow
No multi-factor authentication	Password only, with lockout and rate limiting	Enable Identity's authenticator-app MFA, at least for administrators
Dependency updates	Versions are pinned, but updates are manual	Enable Dependabot for NuGet, npm and GitHub Actions, and add <code>dotnet list package --vulnerable</code> to CI
Monitoring and alerting	Logs are written but no alerts are configured	Add an uptime/error monitor for <code>/health</code> and a log drain with alerts on 5xx responses and lockouts
Rate limiting per instance	In-memory limiter; resets on restart and is per instance	Acceptable for the single-instance deployment; use a distributed limiter (Redis or the platform's edge rules) if the service is scaled out
SQLite on a single volume	One file on the Railway volume, reachable only from the container, so there is no database network surface — but no automatic point-in-time recovery either	Keep the volume, take a copy before a schema change, and move to a managed database if the deployment grows
Uploaded PDFs	Signature-checked but not malware-scanned	Scan uploads in the storage layer if they ever move to object storage
Third-party video	Privacy-enhanced YouTube and Vimeo embeds	Keep the frame allow-list minimal; provide text summaries for accessibility